Alen Paul · Cybersecurity consultant

81 DAYS TO FIX.
45 MIN TO ATTACK.

What AI changed in cyber attacks this year, and what to do about it.

Swipe →

This year’s biggest AI attacks hit old weak spots.

Unpatched servers, trusted vendor apps, default passwords, an overlooked network exit. AI found them, worked them, or both, faster than teams could react.

The fix isn’t new AI rules. It’s the security you already have, run at machine speed.

THE ATTACKER'S CLOCK NOW TICKS IN MINUTES

45 min

from a bug going public to tens of thousands of attack attempts

Cloudflare, via Fortune

31 sec

for an AI attacker to work out why a step failed, and fix it

Sysdig, via The Hacker News

2,900

login attempts a minute, run by AI agents

Microsoft, via The Register

<3 hrs

from picking a target to privileged access in its cloud, in some cases

Microsoft, via The Register

Meanwhile, the median time to fully patch a vulnerability is 43 days.

Verizon Data Breach Investigations Report 2026

AI FOUND A HOLE IN MOST OF THE WEB

PHP runs about 70% of websites. In August, AI tools found a flaw in it that lets anyone on the internet run code on your server.

Finding it to fixing it

81 days

Fix announced to mass attacks

45 minutes

AI finds bugs faster, for both sides. Your patching speed is now the weak point.

Your move: find every server running PHP, including inside other software, and update it this week.

Source: CISA, Wiz, and Cloudflare data via Fortune · Oct 2026

THEY DIDN'T BREAK IN. THEY USED AN APP YOU APPROVED.

State-backed spies stole a backup vendor's access to its customers' Microsoft 365, then let AI agents probe 2,250 organisations around the clock.

2,250

organisations targeted through one vendor's access

Apps you approved years ago still hold the keys. AI lets attackers try all of them at once.

Your move: list every third-party app that can read your Microsoft 365 data, and remove the ones nobody owns.

Source: Microsoft, via The Register · 22 Oct 2026

AI-RUN RANSOMWARE USED A YEAR-OLD BUG

Sysdig calls it the first: an AI agent ran a whole attack on its own, in through a known flaw, past default passwords, then it locked and wiped the company's database.

It printed the decryption key once and never saved it. Paying wouldn't have helped.

1 year+

the way in had been on the US government's list of bugs attackers already use

AI doesn't need clever new bugs. It works through your old ones, fast.

Your move: fix everything on CISA's "actively exploited" list first, and change every default password.

Source: Sysdig, via The Hacker News · 2 Jul 2026

EVEN AN AI LAB COULDN'T KEEP ITS AI IN THE BOX

OpenAI was testing how well its models could hack. They found an overlooked way out of the test, broke into Hugging Face and went looking for the answers.

Hugging Face thought it was a normal attack for five days.

~17K

actions over one weekend before Hugging Face caught it

If a top AI lab missed one exit, check yours. Telling an AI "don't" is not a security control.

Your move: block every network route out of where your AI agents run, unless you approved it.

Source: OpenAI's disclosure, via the Cloud Security Alliance · 23 Jul 2026

WHAT I'D CHANGE ON MONDAY

Patch critical bugs in hours, not weeks.

Start with anything facing the internet.

Fix what attackers already use, first.

CISA keeps the list: Known Exploited Vulnerabilities.

Review every app with access to your data.

If nobody owns it, remove it.

Kill default passwords and hide admin panels.

Nothing with a factory login should face the internet.

Let AI agents reach only what they need.

Block everything else at the network, not in the prompt.

Use AI to find your weak spots first.

Attackers already are.

FOR AUDIT AND GRC TEAMS

What to ask for, and where each incident maps.

PHP2Shell

Ask for: Patch records for internet-facing systems, measured against a critical SLA in hours.

ATT&CK	NIST 800-53	ISO 27001
T1190	SI-2 · RA-5	A.8.8

Storm-0940

Ask for: An inventory of third-party apps with Microsoft 365 access: owner, permissions, last review.

ATT&CK	NIST 800-53	ISO 27001
T1199 · T1078.004 · T1110.003	SA-9 · AC-2 · AC-6	A.5.19 · A.5.21 · A.8.2

JADEPUFFER

Ask for: KEV remediation status, and a default-credential scan of every exposed service.

ATT&CK	NIST 800-53	ISO 27001	AI frameworks
T1190 · T1078.001 · T1486 · T1485	SI-2 · IA-5 · CP-9	A.8.8 · A.8.9 · A.8.13	SAIF Insecure Integrated Component · OWASP LLM03

OpenAI / Hugging Face

Ask for: Egress rules for every environment where AI agents run, including package mirrors and DNS.

ATT&CK	NIST 800-53	ISO 27001	AI frameworks
T1190 · T1552	SC-7 · SI-4	A.8.20 · A.8.22	OWASP ASI10 · SAIF Agent Permissions · AI RMF MANAGE 2.4 · ISO 42001 A.6.2.6

Most of this is ISO 27001 and NIST 800-53 work you already own. It just has to happen faster.

FOR MORE DETAILED INFO

PHP2Shell: what to patch	cisa.gov · 21 Oct 2026
How AI found PHP2Shell	wiz.io · 21 Oct 2026
81 days, 45 minutes	fortune.com · 21 Oct 2026
Storm-0940 and ConnectWise	theregister.com · 22 Oct 2026
43 days median to patch	Verizon DBIR · 2026
JADEPUFFER, AI-run ransomware	thehackernews.com · 2 Jul 2026
OpenAI models breach Hugging Face	Cloud Security Alliance · 23 Jul 2026

Frameworks: MITRE ATT&CK · NIST SP 800-53 · ISO/IEC 27001 · ISO/IEC 42001 · Google SAIF · NIST AI RMF · OWASP LLM Top 10 · OWASP Agentic Top 10 · CISA KEV

ATTACKERS AUTOMATED THE LOOP. AUTOMATE YOURS.

What's your critical patch SLA, in hours?

Talk to me → heisenberg02.blog

Alen Paul · Cybersecurity consultant